CONECTA NEXUS — ESPECIFICACIÓN TÉCNICA SPRINT 1

Cimientos de Identidad, Perfiles y Cumplimiento (Microservicios: auth & profile)

Atributo del Proyecto	Detalle Oficial
Institución y Programa	Universidad Francisco de Paula Santander (UFPS Cúcuta) — Ingeniería de Sistemas
Asignatura / Docente Evaluador	Desarrollo de Aplicaciones Basadas en Microservicios / Seminario Investigativo III — Carlos Eduardo Pardo García
Integrantes del Equipo	José Manuel Pérez Rodríguez (1152375) • Juan Diego Sarmiento Barroyeta (1152376) • Nelson Enrique Conde Tarazona (1152391)
Ventana del Sprint 1	12 Oct 2026 – 22 Oct 2026 (10 días calendario) | Capacidad comprometida: 33 Puntos de Historia (33% del MVP)
Alcance Funcional (Backlog)	HU-01 (5 PH), HU-02 (5 PH), HU-03 (5 PH), HU-04 (8 PH), HU-05 (10 PH) | Requerimientos: RF01 a RF10, RF31, RF32
Code Owners Asignados	auth (FastAPI): Anorak & Nelson | profile (Django DRF): Anorak & Juan | Frontend base: Nuxt 4

1. Resumen Operativo del Sprint 1 y Criterios de Completitud (DoD)

El Sprint 1 establece los cimientos de identidad multi-rol, cumplimiento normativo de protección de datos personales (Ley Estatutaria 1581 de 2012) y gestión de perfiles académicos y corporativos. Se implementa bajo el patrón Database-per-Service sobre PostgreSQL 16 (db_auth y db_profiles) orquestado localmente en Podman/Docker Compose.

- **Infraestructura Local y Flujo Git:** Puesta a punto de repositorios en GitHub, reglas de protección de ramas (develop y main), convención de código/commits en inglés, cobertura de pruebas unitarias >= 80% y script setup.sh con inicialización multi-DB en PostgreSQL 16.
- **Microservicio auth (FastAPI) — 10 PH:** Implementación de HU-01 (Registro multi-rol STUDENT y COMPANY, 5 PH) y HU-02 (Login seguro OAuth2, emisión/rotación de tokens JWT con firma asimétrica RS256 y revocación en logout, 5 PH). Incluye endpoint /api/v1/auth/verify con latencia < 50 ms.
- **Microservicio profile (Django + DRF) — 23 PH:** Implementación de HU-03 (Consentimiento informado Ley 1581 trazable y bloqueante, 5 PH), HU-04 (Perfil Académico de Estudiante con semestre validado entre 6.° y 10.° y código/carrera inmutables según RB-08/RF10, 8 PH) y HU-05 (Ficha Corporativa de Empresa con validación de NIT y vistas públicas restringidas RF08, 10 PH).

- **Meta de Cierre (22 de Octubre de 2026):** 33 PH completados. Usuarios autenticados con tokens JWT RS256 activos, consentimiento legal registrado y perfiles persistidos con vistas públicas protegidas.

2. Catálogo de APIs REST a Implementar (Sprint 1)

Ambos microservicios exponen sus contratos OpenAPI bajo el prefijo /api/v1/*. A continuación se detallan los endpoints, historias de usuario asociadas, requerimientos funcionales y reglas de negocio.

2.1. Microservicio auth (FastAPI) — Base de datos: db_auth

Método	Endpoint	HU / RF	Funcionalidad Principal	Reglas de Negocio y Detalles Técnicos
POST	/api/v1/auth/register	HU-01 RF01, RF03	Autorregistro de nuevas cuentas asignando rol explícito (STUDENT o COMPANY).	• Validar correo institucional (@ufps.edu.co) o corporativo y verificar unicidad. • Hashear contraseña con Argon2 o bcrypt. • Prohibir creación de rol ADMIN por vía pública.
POST	/api/v1/auth/login	HU-02 RF02, RF03	Autenticación OAuth2 (Password Flow) y emisión de access_token (15 min) y refresh_token (7 días).	• Verificar cuenta activa (is_active = True). • Firmar JWT con llave privada RSA (RS256) incluyendo sub, role y scope. • Tiempo de respuesta objetivo < 50 ms.
POST	/api/v1/auth/refresh	HU-02 RF02	Renovación del access_token mediante un refresh_token válido.	• Validar que el refresh_token no esté expirado ni revocado en db_auth. • Aplicar rotación de Refresh Token (invalidar el anterior y emitir uno nuevo).
POST	/api/v1/auth/logout	HU-02 RF05	Cierre explícito de sesión activa y revocación de autorizaciones.	• Marcar is_revoked = True y registrar revoked_at en la tabla refresh_tokens

				para impedir reutilización.
GET	/api/v1/auth/verify	DoD auth RF03	Verificación rápida de sesión activa, firma RS256 y vigencia del JWT.	• Consumido por el API Gateway y microservicios internos para validar sesión y permisos antes de enrutar.
POST	/api/v1/auth/password-reset/request	HU-02 RF04	Solicitud de recuperación de contraseña por correo verificado.	• Genera token temporal de un solo uso (expiración 15 min) y dispara el envío del enlace seguro.
POST	/api/v1/auth/password-reset/confirm	HU-02 RF04	Confirmación y actualización de contraseña con token temporal.	• Valida vigencia y no uso previo del token, actualiza password_hash y revoca sesiones activas del usuario.
PATCH	/api/v1/auth/users/{user_id}/status	RF03 RF32	Activación o suspensión cautelar de una cuenta de usuario.	• Restringido exclusivamente al scope user:status:write (Rol ADMIN / servicio moderation en Sprint 3).

2.2. Microservicio profile (Django + DRF) — Base de datos: db_profiles

Método	Endpoint	HU / RF	Funcionalidad Principal	Reglas de Negocio y Detalles Técnicos
POST	/api/v1/profiles/consent	HU-03 RF09	Registro explícito y trazable del consentimiento informado (Ley 1581 de 2012).	• Bloqueante: Requisito previo obligatorio para activar y operar el perfil. • Registra timestamp UTC, IP, User-Agent y versión de política.
GET	/api/v1/profiles/consent/me	HU-03 RF09	Consulta del estado e historial de	• Permite al frontend en Nuxt 4 verificar si

			consentimiento del usuario autenticado.	debe exigir el modal legal al iniciar sesión.
POST	/api/v1/profiles/students/me	HU-04 RF06, RF10	Creación inicial del perfil académico del estudiante autenticado.	• Validar current_semester estrictamente entre 6 y 10. • Fija student_code y academic_program como inmutables tras el registro (RB-08 / RF10).
GET	/api/v1/profiles/students/me	HU-04 RF06	Consulta del perfil académico propio (vista privada completa).	• Extrae el user_id del claim sub del JWT RS256 e incluye datos de contacto propios.
PATCH	/api/v1/profiles/students/me	HU-04 RF06, RF10	Actualización parcial de semestre, asignaturas, habilidades e intereses.	• Regla RB-08 / RF10: Bloquear cualquier modificación sobre student_code o academic_program (read_only o HTTP 400).
GET	/api/v1/profiles/students/{user_id}/public	HU-04 RF08	Vista pública restringida del perfil académico de un estudiante.	• Cumplimiento Ley 1581 (RF08): Omite contact_email y contact_phone antes de aceptación formal.
POST	/api/v1/profiles/companies/me	HU-05 RF07	Creación inicial de la ficha corporativa de la empresa aliada.	• Valida unicidad y formato del NIT, razón social, sector productivo, descripción y sitio web oficial.
GET	/api/v1/profiles/companies/me	HU-05 RF07	Consulta de la ficha corporativa propia (vista privada completa).	• Retorna tanto la ficha institucional como los canales internos de contacto.
PATCH	/api/v1/profiles/companies/me	HU-05 RF07	Actualización de descripción operativa, sector,	• Protege la inmutabilidad del NIT validado y actualiza

			web y contacto empresarial.	el sello updated_at en UTC.
GET	/api/v1/profiles/companies/{user_id}/public	HU-05 RF08	Vista pública restringida de la ficha corporativa para estudiantes.	• Cumplimiento RF08: Muestra razón social, sector, descripción y enlaces web, ocultando correo y teléfono directo.
GET	/api/v1/profiles/internal/{user_id}/eligibility	Integración RF06, RF31	Endpoint interno inter-servicio para validar elegibilidad y revelar contactos.	• Consumido síncronamente por application (Sprint 3) para validar semestre 6.°-10.°, Ley 1581 y revelar contactos tras aceptación (RB-05).

3. Modelo de Datos Relacional en PostgreSQL 16 (Database-per-Service)

Siguiendo el principio de Contextos Delimitados (Bounded Contexts), ningún microservicio accede directamente a las tablas de otro. No existen llaves foráneas físicas entre db_auth y db_profiles; la correlación lógica se realiza mediante el UUID del usuario (user_id / claim sub).

3.1. Esquema de Base de Datos: db_auth (Microservicio auth)

A. Tabla: users (Identidad y Credenciales)

Columna	Tipo de Dato (PostgreSQL)	Restricciones	Descripción Técnica
id	UUID	PRIMARY KEY DEFAULT gen_random_uuid()	Identificador único global del usuario (claim sub en el JWT).
email	VARCHAR(255)	UNIQUE NOT NULL	Correo electrónico institucional (@ufps.edu.co) o corporativo.
password_hash	VARCHAR(255)	NOT NULL	Hash criptográfico de la contraseña (Argon2 / bcrypt).
role	VARCHAR(20)	NOT NULL CHECK (role IN ('STUDENT', 'COMPANY', 'ADMIN'))	Rol operativo asignado al usuario dentro de la plataforma (RF01, RF03).

is_active	BOOLEAN	NOT NULL DEFAULT TRUE	Estado de la cuenta; permite bloqueo o suspensión cautelar (RF03, RF32).
is_email_verified	BOOLEAN	NOT NULL DEFAULT FALSE	Indica si el correo electrónico ya fue verificado.
last_login_at	TIMESTAMPTZ	NULL	Sello de tiempo UTC del último inicio de sesión exitoso.
created_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Sello de tiempo UTC de creación del registro (RNF03).
updated_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Sello de tiempo UTC de última actualización.

B. Tabla: refresh_tokens (Control de Sesiones y Revocación — HU-02 / RF05)

Columna	Tipo de Dato (PostgreSQL)	Restricciones	Descripción Técnica
id	UUID	PRIMARY KEY DEFAULT gen_random_uuid()	Identificador único de la sesión/token (claim jti).
user_id	UUID	NOT NULL REFERENCES users(id) ON DELETE CASCADE	Usuario propietario de la sesión activa.
token_hash	VARCHAR(255)	UNIQUE NOT NULL	Hash SHA-256 del refresh token emitido.
expires_at	TIMESTAMPTZ	NOT NULL	Fecha y hora UTC límite de vigencia del refresh token.
is_revoked	BOOLEAN	NOT NULL DEFAULT FALSE	Cambia a TRUE al cerrar sesión (RF05) o rotar el token.
revoked_at	TIMESTAMPTZ	NULL	Sello de tiempo UTC del momento exacto de revocación.

ip_address	INET	NULL	Dirección IP del cliente al iniciar sesión (trazabilidad).
user_agent	VARCHAR(512)	NULL	Metadatos del navegador o dispositivo del cliente.
created_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Fecha y hora UTC de emisión del token.

C. Tabla: password_reset_tokens (Recuperación de Contraseña — RF04)

Columna	Tipo de Dato (PostgreSQL)	Restricciones	Descripción Técnica
id	UUID	PRIMARY KEY DEFAULT gen_random_uuid()	Identificador único del registro de recuperación.
user_id	UUID	NOT NULL REFERENCES users(id) ON DELETE CASCADE	Usuario que solicita restablecer su contraseña.
token_hash	VARCHAR(255)	UNIQUE NOT NULL	Hash del token temporal enviado al correo verificado.
expires_at	TIMESTAMPTZ	NOT NULL	Expiración corta de seguridad (ej. +15 minutos).
is_used	BOOLEAN	NOT NULL DEFAULT FALSE	Garantiza que el enlace temporal solo se utilice una vez.
created_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Fecha y hora UTC de solicitud.

3.2. Esquema de Base de Datos: db_profiles (Microservicio profile)

A. Tabla: data_consents (Bitácora de Consentimiento Ley 1581 — HU-03 / RF09)

Columna	Tipo de Dato (PostgreSQL)	Restricciones	Descripción Técnica
id	UUID	PRIMARY KEY DEFAULT gen_random_uuid()	Identificador único del registro legal de consentimiento.

user_id	UUID	NOT NULL (Indexado)	UUID del usuario autenticado proveniente del token de auth.
policy_version	VARCHAR(20)	NOT NULL DEFAULT 'v1.0-2026'	Versión de la política de tratamiento de datos aceptada.
is_accepted	BOOLEAN	NOT NULL CHECK (is_accepted = TRUE)	Confirmación explícita de autorización de Habeas Data.
ip_address	INET	NOT NULL	Dirección IP de origen como evidencia de aceptación electrónica.
user_agent	TEXT	NOT NULL	Cadena User-Agent del navegador como soporte de trazabilidad.
accepted_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Sello de tiempo inmutable UTC de la autorización (RNF03).

B. Tabla: student_profiles (Perfil Académico — HU-04 / RF06, RF08, RF10)

Columna	Tipo de Dato (PostgreSQL)	Restricciones	Descripción Técnica
id	UUID	PRIMARY KEY DEFAULT gen_random_uuid()	Identificador interno del perfil estudiantil.
user_id	UUID	UNIQUE NOT NULL	Referencia lógica 1:1 al id del usuario en db_auth.
full_name	VARCHAR(150)	NOT NULL	Nombre completo del estudiante.
student_code	VARCHAR(15)	UNIQUE NOT NULL	Código estudiantil UFPS (ej. 1152375). Inmutable tras creación (RB-08 / RF10).
academic_program	VARCHAR(120)	NOT NULL DEFAULT 'Ingeniería de Sistemas'	Programa académico. Inmutable tras creación (RF10).

current_semester	SMALLINT	NOT NULL CHECK (current_semester BETWEEN 6 AND 10)	Semestre activo validado entre 6.° y 10.° semestre (RF06).
completed_courses	JSONB	NOT NULL DEFAULT '[]'::jsonb	Listado de asignaturas cursadas/activas (ej. ["Microservicios", "Seminario III"]).
technical_skills	JSONB	NOT NULL DEFAULT '[]'::jsonb	Habilidades técnicas (ej. ["Python", "FastAPI", "Django", "PostgreSQL"]).
interest_areas	JSONB	NOT NULL DEFAULT '[]'::jsonb	Áreas de interés académico y profesional del alumno.
bio	TEXT	NULL	Resumen o presentación académica del estudiante.
contact_email	VARCHAR(255)	NOT NULL	Correo institucional directo (Oculto en vista pública RF08; revelado en RF31).
contact_phone	VARCHAR(25)	NULL	Teléfono de contacto (Oculto en vista pública RF08; revelado en RF31).
is_profile_complete	BOOLEAN	NOT NULL DEFAULT FALSE	Indica si cumple Ley 1581 y campos requeridos para poder postular.
created_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Fecha y hora UTC de creación del perfil.
updated_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Fecha y hora UTC de última actualización.

C. Tabla: company_profiles (Ficha Corporativa — HU-05 / RF07, RF08)

Columna	Tipo de Dato (PostgreSQL)	Restricciones	Descripción Técnica
id	UUID	PRIMARY KEY DEFAULT gen_random_uuid()	Identificador interno de la ficha corporativa.

user_id	UUID	UNIQUE NOT NULL	Referencia lógica 1:1 al id del usuario en db_auth.
nit	VARCHAR(25)	UNIQUE NOT NULL	NIT empresarial con dígito de verificación (HU-05).
business_name	VARCHAR(200)	NOT NULL	Razón social oficial de la organización aliada (RF07).
economic_sector	VARCHAR(100)	NOT NULL	Sector productivo o industrial (RF07).
description	TEXT	NOT NULL	Descripción operativa y reseña institucional (RF07).
website_url	VARCHAR(255)	NULL	Sitio web oficial de verificación de la empresa (RF07).
public_links	JSONB	NOT NULL DEFAULT '[]'::jsonb	Enlaces públicos adicionales opcionales (LinkedIn, redes oficiales).
contact_name	VARCHAR(150)	NOT NULL	Nombre del representante o contacto institucional.
contact_email	VARCHAR(255)	NOT NULL	Correo corporativo directo (Oculto en vista pública RF08; revelado en RF31).
contact_phone	VARCHAR(25)	NOT NULL	Teléfono corporativo directo (Oculto en vista pública RF08; revelado en RF31).
is_verified	BOOLEAN	NOT NULL DEFAULT TRUE	Estado de habilitación de la empresa para publicar problemáticas.
created_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Fecha y hora UTC de registro.
updated_at	TIMESTAMPTZ	NOT NULL DEFAULT CURRENT_TIMESTAMP	Fecha y hora UTC de última actualización.

4. Seguridad OAuth2, Scopes RBAC y Estructura del JWT (RS256)

4.1. Matriz de Permisos (Scopes OAuth2) por Rol (RF03 / RNF-01)

Rol (role)	Scopes OAuth2 Asignados en el JWT (claim scope)	Alcance Operativo en Conecta Nexus
STUDENT	consent:write consent:read profile:student:read profile:student:write profile:company:read_public challenge:read application:create application:read_own	Autorizar Habeas Data (HU-03), crear/editar su perfil académico (HU-04), consultar fichas públicas de empresas (RF08), explorar retos abiertos (Sprint 2) y postularse (Sprint 3).
COMPANY	consent:write consent:read profile:company:read profile:company:write profile:student:read_public challenge:create challenge:read_own challenge:write_own application:read_received application:decide	Autorizar Habeas Data (HU-03), gestionar su ficha corporativa (HU-05), ver perfiles públicos de estudiantes, publicar/administrar retos propios (Sprint 2) y decidir solicitudes (Sprint 3).
ADMIN	profile:read_all challenge:read_all challenge:moderate user:status:write audit:read	Supervisar publicaciones, ejecutar suspensiones cautelares de cuentas o retos infractores y auditar bitácoras inmutables institucionales (RF32 / Sprint 3).

4.2. Estructura Estándar del Payload JWT (OAuth2 RS256)

El microservicio auth firma el token con su llave privada RSA de 2048 bits (algoritmo RS256). El API Gateway y el microservicio profile validan la firma localmente usando únicamente la llave pública RSA:


```
{
  "iss": "https://auth.conectanexus.ufps.edu.co",
  "aud": [
    "conecta-nexus-gateway",
    "conecta-nexus-services"
  ],
  "sub": "f47ac10b-58cc-4372-a567-0e02b2c3d479",
  "jti": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
  "iat": 1792341600,
  "nbf": 1792341600,
  "exp": 1792342500,
  "type": "access",
  "email": "josemanuelpr@ufps.edu.co",
  "role": "STUDENT",
  "is_active": true,
  "scope": "consent:write consent:read profile:student:read profile:student:write
profile:company:read_public challenge:read application:create application:read_own"
}
```

5. Decisión de Arquitectura (ADR-002) y Lineamientos de Desarrollo

5.1. ADR-002: Adopción de Firma Asimétrica RS256 para Tokens JWT

Campo ADR	Especificación
ID y Título	ADR-002: Adopción de firma criptográfica asimétrica RS256 (RSA-SHA256) para autenticación JWT OAuth2.
Estado y Fecha	Aceptado — Sprint 1 (Octubre de 2026).
Contexto	Conecta Nexus consta de 6 microservicios desacoplados y un API Gateway. Se requiere autenticación stateless con latencia < 50 ms y control RBAC (RNF-01) sin acoplar bases de datos ni exponer secretos de firma en servicios secundarios.
Decisión	Se adopta RS256 con par de llaves RSA de 2048 bits. El microservicio auth custodia en exclusividad la llave privada (jwt_private.pem) para emitir tokens. El API Gateway, profile y demás servicios montan únicamente la llave pública (jwt_public.pem) en modo solo lectura para verificar firma, iss, aud, exp y scopes.
Consecuencias y Mitigación	• Cumple el principio de menor privilegio (Zero Trust): ningún servicio secundario puede falsificar tokens. • Los archivos .pem se excluyen de Git (.gitignore) y se inyectan mediante volúmenes en Podman/Docker Compose local y Google Cloud Secret Manager en Cloud Run.

5.2. Reglas de Flujo de Trabajo y Calidad para el Equipo (Sprint 1)

- **Idioma del Código y Git:** Todo el código fuente, nombres de tablas/columnas, endpoints, ramas y mensajes de commit deben escribirse estrictamente en inglés (Conventional Commits: feat(auth): ..., feat(profile): ...).
- **Autenticación Stateless en Django DRF (profile):** Dado que db_profiles no contiene la tabla users de db_auth, profile implementa RS256JWTAuthentication construyendo un usuario en memoria (StatelessJWTUser) a partir del payload verificado con la llave pública RSA.
- **Reglas de Negocio Innegociables en Sprint 1:** 1) Consentimiento Ley 1581 previo obligatorio (HU-03 / RF09); 2) Semestre estudiantil validado entre 6.° y 10.° (HU-04 / RF06); 3) Inmutabilidad estricta de student_code y academic_program tras creación (RB-08 / RF10); 4) Ocultamiento de correo y teléfono directo en vistas públicas (RF08).
- **Criterios de Pull Request (PR):** Revisión obligatoria por el par Code Owner asignado, cobertura de pruebas unitarias con Pytest >= 80%, checks de GitHub Actions en verde y método de integración 'Create a merge commit' (sin Squash).